



FLEET & SHORE PERSONNEL TRAINING

Cyber Security

Protecting our ships, our data and our people in a connected maritime world.

IMO Res. MSC.428(98)

ISM Code

BIMCO Guidelines v4

Company SMS — M11

What we will cover

01 Introduction & Fundamentals

IT, OT and why the ship is a target

02 Cyber Security Policy

Company commitments and responsibilities

03 Threats & Threat Actors

Who attacks, why, and what they want

04 Network & Email Threats

DoS, spoofing, phishing, social engineering

05 Malware

Viruses, worms, Trojans and spyware

06 Vulnerabilities & Risk

Assessing the ship, scoring the risk

07 Protection Measures

Technical and procedural defences

08 You Are the Front Line

Daily habits that stop attacks

09 Contingency & Response

When something goes wrong

10 Reporting & Contacts

Who to call and what to record



SECTION 01

Introduction & Fundamentals

Modern ships are networked, complex and permanently connected. That connectivity delivers efficiency — and exposure.

01

The ship is no longer an isolated island

Ships are interconnected via the World Wide Web, and electronic equipment on board grows more complex every year — increasing both the attack surface and the risk of human error.

5

Main asset types on board: plant & machinery,
OT, IT, RF communications and navigation
systems

2

Attack categories: untargeted (you are one of
many) and targeted (you are the objective)

4

Stages of every attack: survey, delivery, breach
and effect



Always online — Satellite links, remote maintenance and shore-side integration keep the vessel permanently reachable.



Many stakeholders — Owners, managers, charterers, makers and contractors — which can leave the IT infrastructure without a clear owner.



Rapid change — New vulnerabilities appear constantly in operating systems, software libraries and applications.

Information Technology vs. Operational Technology

Both must be protected. A failure in either can put the ship, the crew, the cargo and the environment at risk.



IT — Information Technology

At risk: mainly finance and reputation

- IT networks and servers
- E-mail and administration systems
- Crew lists, certificates and personal data
- Planned maintenance and requisitioning
- Electronic manuals and permits to work
- Charter party, notices of readiness, bills of lading



OT — Operational Technology

At risk: life, property and the environment

- PLCs, SCADA and alarm/monitoring systems
- ECDIS, GPS/GNSS, AIS, radar and NavTex
- Propulsion, steering and power management
- Cargo, ballast and loading computers
- Remote support for engines and equipment
- Data loggers and dynamic positioning

DEFINITION

What is cyber security?

"The collection of tools, policies, security concepts, safeguards, guidelines, risk-management approaches, actions, training, best practices, assurance and technologies used to protect the cyber environment and the organisation's and users' assets."



The cyber environment

The interconnected networks of IT and cyber-physical systems — electronic, computer-based and wireless — plus the information, services and business functions that exist only in cyberspace.



Organisation and user assets

Connected computing devices, personnel, infrastructure, applications, services, telecommunication systems, and all data transmitted, processed or stored.



No single solution

The varied nature of threats means no one approach addresses all risks. Any strategy must be reviewed regularly as technology and the business change.



More than keeping hackers out

Cyber security also maintains the integrity and availability of information and systems — ensuring business continuity and the continuing usefulness of our digital assets, not only their confidentiality.

The six elements of information security



Availability

Is the system working when you need it?
Prevents unauthorised withholding of
information or resources.



Authorization

Who is given access? Only approved users may
use a resource, and only in approved ways.



Authenticity

How do I know who sent this? Confirms the party
in a transaction is who they claim to be.



Integrity

Has the data changed? Keeps digital objects
accurate, complete and trustworthy over time.



Confidentiality

Information is accessible only to authorised
individuals — in any form: paper, electronic,
spoken.



Non-repudiation

Neither party can later deny having sent or
received the message or transaction.

Cyber security and cyber safety

Both have equal potential to affect the safety of personnel, the ship and the cargo. An effective response to either is based on training and awareness.



Cyber security

Protection from deliberate acts

- Protects IT, OT and data from unauthorised access
- Prevents manipulation and disruption by threat actors
- Concerned with confidentiality, integrity and availability
- Driven by an intelligent, motivated adversary



Cyber safety

Protection from loss or failure

- Covers loss of availability or integrity of safety-critical data and OT
- Failures during software maintenance and patching
- Loss or manipulation of external sensor data, including GNSS
- May arise without any attacker being involved at all

Why the maritime industry is vulnerable



Fragmented accountability

Multiple stakeholders operate and charter the ship, which can leave no single owner responsible for the IT infrastructure.



Permanent connectivity

The ship is online and interfaces continuously with the wider global supply chain.



Sensitive data shared ashore

Business-critical and commercially sensitive information is exchanged with shore-based service providers.



Computer-controlled critical systems

Safety and environmental protection now depend on digital control systems.



Big data, smart ships and IoT

More available information means more for attackers to exploit — and a greater need for robust protection.



Awareness gaps

Crew and contractors bring their own devices and habits on board; cyber hygiene varies widely.

Consequences of poor cyber security

Impacts may occur at individual ship level or at fleet level — the latter is likely to be far worse and could severely disrupt the operating company.



Safety of life

Harm to the health and safety of crew and anyone affected by the ship's activities.



Loss of control

Disruption caused by the ship no longer functioning or sailing as intended — endangering other ships, structures and the environment.



Pollution

Environmental damage where machinery, cargo or ballast control systems are compromised.



Loss of information

Commercially sensitive or personal data exposed, with regulatory and contractual consequences.



Criminal exploitation

Kidnap, piracy, fraud, theft of cargo and the imposition of ransomware.



Commercial damage

Loss of customer and industry confidence, reputational damage and severe financial cost.

Five asset types you are protecting

A ship encompasses waterborne activities and remote elements such as navigation signals. Loss or compromise of any asset type affects safety, operability and efficiency.



Plant & machinery

Engines, pumps, valves, steering and auxiliary systems.



Operational technology

PLC, SCADA, sensors and control loops managing physical processes.



Information technology

Servers, workstations, e-mail and administrative software.



RF communications

Satellite, VHF/MF/HF, Wi-Fi and remote support links.



Navigation systems

ECDIS, GNSS, AIS, radar, ARPA and NavTex.

Resilience of ship systems

The higher the potential safety risk, the higher the required level of redundancy and availability. Situational awareness depends entirely on the integrity of sensor data.



Human threat actors

Deliberate interference with sensors, control systems or data — including GNSS jamming and spoofing.



Natural causes

Solar events, weather, flora and fauna can damage, disable or significantly impair ship systems.



Data loss or corruption

Any of the above may cause loss of integrity or availability of a subsystem and its stored data.



Redundancy is the answer

Critical systems are duplicated and monitored so that a single failure never removes situational awareness.



Remember

Not every incident is an attack. A patch applied badly, a failed sensor or a solar storm can produce exactly the same operational effect — and must be handled with the same discipline.



SECTION 02

Cyber Security Policy

A security policy is only as valuable as the knowledge and effort of the people who follow it.

02

What the policy requires of you

The policy guides employees towards understanding and adhering to the security practices relevant to their job responsibilities. Top Management is committed to enforcing the behaviours it mandates.



Contextual training

Every user receives security training matched to the scope of their duties and responsibilities.



Areas of caution

The programme identifies where to be careful, the appropriate security measures, and how to apply them.



Everyday practices

Correct password use, anti-virus and anti-spam tools, resisting social engineering, and backing up data.



Reporting channels

Clear routes to report suspected incidents or policy violations — early reporting limits damage.



Continual refresh

Because vulnerabilities, risks and regulations change, training is repeated and updated, not delivered once.

It is the policy of the Company that...

- Information and systems identified as vulnerable to cyber attack are protected from loss of confidentiality, integrity and availability.
- All regulatory and legislative requirements relating to information and cyber security are met.
- Cyber Security Contingency Plans are produced, maintained and tested.
- Cyber security training is available and delivered to all personnel, ashore and afloat.
- All actual or suspected security breaches are reported to, and investigated by, the Information Security Manager.
- Supporting guidance and procedures exist for incident handling, information backup, system access, virus controls, passwords and encryption.
- All managers are directly responsible for implementing the policy within their business areas and for the adherence of their staff.
- Compliance with the Cyber Security Policy is mandatory for every employee, contractor and visitor with system access.



Information takes many forms

- Printed or written on paper
- Stored electronically or on tape/video
- Transmitted by post or electronically
- Spoken in conversation

Who is responsible for what



Information Security / IT Manager

Single point of accountability for IT, information systems and data security. Initiates, develops and maintains policies and procedures; provides advice and guidance; keeps cyber security on the organisational radar; ensures security strategies are followed.



Heads of department (ashore)

Promptly report problems and breakdowns in communication systems to the IT Manager so remedial measures can be implemented as soon as possible. Implement the policy within their business area.



The Master

Ensures all personnel on board are aware of and comply with the Cyber Security Policy; controls on-board passwords; ensures visitors and contractors are supervised; reports incidents to the Company without delay.



Every user — ashore and on board

Follows the procedures, protects credentials, uses only authorised equipment and media, stays alert to suspicious activity, and reports anything unusual immediately.



SECTION 03

Threats & Threat Actors

Who attacks a ship, what motivates them, and what effect they are trying to achieve.

03

Vulnerability, threat and attack are not the same thing



Vulnerability

A weak point

A loophole that could be used to gain access to computer- or network-related resources. It represents a "potential for unintended use". A vulnerability is NOT an attack — it is an exploitable weakness, such as a software bug, a weak protocol, or an unpatched operating system.



Threat

A potential violation

A possible violation of security — malicious or otherwise — that exists because of the weaknesses found in most systems. Threats include people, natural events and accidents, and they exist whether or not anyone chooses to act on them.



Attack

An intentional act

An unfriendly action taken with the express purpose of harming an asset or violating security. It may destroy, modify, fabricate, interrupt or intercept data. Countermeasures are the actions taken to reduce or mitigate that harm.

Six reasons someone attacks a ship



Cyber misuse

Low-level vandalism, website defacement and unauthorised access — script kiddies or disgruntled insiders and contractors.



Activism ("hacktivism")

Publicity or pressure for a cause: preventing the handling of a cargo, or disrupting the ship or its operator.



Espionage

Unauthorised access to sensitive commercial, technical or personal information for competitive or state advantage.



Organised crime

Financial gain: ransomware, fraud, theft of data, manipulation of cargo records and facilitation of physical theft.



Terrorism

Disruption of economies and critical national infrastructure; harm to people, property and the environment.



State-sponsored action

Political gain, intelligence collection and pre-positioning within critical maritime infrastructure.

Who they are, what drives them, what they want

Group	Motivation	Objective
Activists (incl. disgruntled employees)	Reputational damage Disruption of operations Media attention	Destruction of data · Publication of sensitive data · Denial of access to the service or system
Criminals	Financial gain Commercial espionage Industrial espionage	Selling stolen data · Ransoming stolen data · Ransoming system operability · Arranging fraudulent transportation of cargo
Opportunists	The challenge	Getting through cyber security defences · Financial gain
States, state-sponsored organisations, terrorists	Political gain Espionage	Gaining knowledge · Disruption to economies and critical national infrastructure

Source: company Cyber Security Manual, Section 3 — Identify Threats.

What threat actors are trying to achieve

Whatever the motivation, the attacker has a desired outcome — aimed at the business, the ship or a ship subsystem.



Destroy

Cargo, ship or port made permanently unavailable — physical or logical destruction.



Deny

Access to systems or data blocked, for extortion or to enable a physical attack such as kidnap and ransom.



Delay

Timely operation of the ship or its subsystems is slowed, causing knock-on business impact or penalties.



Degrade

Performance is reduced without full failure — often the hardest effect to detect.



Detect

Tracking of people, cargo or ship position to enable physical theft or cargo manipulation.



Distract

A sensor state is altered to create a distraction while data or information is extracted elsewhere.

Untargeted vs. targeted attacks

In an untargeted attack you are one of many potential victims. In a targeted attack, the company or the ship is the intended objective — and the attacker will be far more persistent.



Untargeted — indirect

Tools and techniques freely available on the internet

- Malware that encrypts data until the distributor decrypts it (ransomware)
- Scanning or attacking large portions of the internet at random
- Mass e-mails with hyperlinks to fake websites (phishing)
- Water holing: a fake or compromised website that legitimate users visit
- Brute force against weak or default credentials



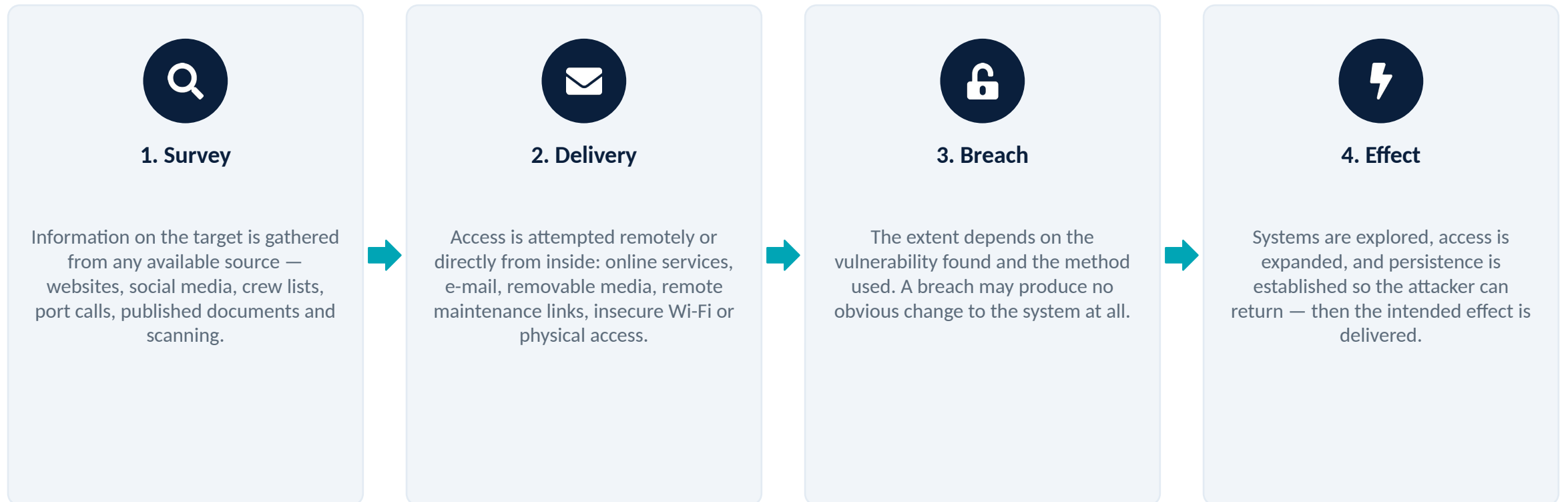
Targeted — direct

More sophisticated, better resourced, persistent

- Spear-phishing: personal e-mails carrying malicious software or links
- Botnets delivering DDoS attacks that overload the ship's servers
- Subverting the supply chain — attacking equipment or software before delivery
- Social engineering of specific crew or shore staff
- Exploiting remote maintenance access provided to suppliers

The four stages of a cyber attack

The time taken to prepare an attack depends on the attacker's motivation and on the resilience of our technical and procedural controls.





SECTION 04

Network & E-mail Threats

Denial of service, spoofing, social engineering and phishing — the techniques you will actually meet.

Networks you will encounter on board

A network is a group of two or more computer systems linked together. Networks are also classified by topology, protocol, ownership, and by whether they carry voice, data or both.



LAN — Local Area Network

Computers physically close together, connected by cable into a single network — for example the machinery-space workstations or the bridge network.



WAN — Wide Area Network

Computers further apart, connected by telephone lines, satellite links or radio waves — the link between ship and shore office.



VPN — Virtual Private Network

A private data network built on top of the internet. Hosts inside use encryption to talk to one another; hosts outside are excluded, even on a public network.

DoS and DDoS attacks

DoS originates from a single computer; DDoS originates simultaneously from many. Either can be malicious or the accidental result of administrator or programming error.



Consumption of scarce resources

Many connections are opened at once until network bandwidth, memory or processing capacity is exhausted and legitimate users are locked out.



Destruction or alteration of configuration

Configuration information is changed so that the system can no longer route, authenticate or serve correctly.



Physical destruction or alteration

Network components themselves are damaged or reconfigured beyond use.



Why it still hurts

Most DoS attacks steal nothing and destroy no hardware. They do not affect confidentiality or integrity. But they cost opportunity — customers go elsewhere, the reputation is tarnished, and a ship that cannot receive or send data cannot operate normally.

How a distributed attack is assembled

1

Client

The machine from which the attacker coordinates everything. It never touches the victim directly.

2

Handlers

Three or four compromised hosts under the attacker's direct control. They act like generals on a battlefield, relaying orders.

3

Agents / zombies

Hundreds to thousands of compromised machines that actually generate the flood of traffic. Their owners usually have no idea.

4

Scan and exploit

Automated tools probe 100,000+ hosts for weaknesses, then use dictionary attacks and known vulnerabilities to take root privileges. It takes under 5 seconds to disable a host and install the attack tools.

5

Target

The victim server or network is overwhelmed. Even unskilled individuals can launch sophisticated attacks once the vectors are in place.

E-mail is how most attacks reach you

To be valid, an e-mail address needs a user ID, a domain name and an "@" symbol. Almost everything else about a message — including the "From" and "Reply To" fields — can be forged.

3

Things a recipient must judge: confidentiality, integrity and authentication of the message

2

Biggest hazards: malicious attachments and, increasingly, the message body itself

0

Legitimate businesses that will ever ask you by e-mail for a password, PIN or card number



Filters — Intercept incoming or outgoing e-mail and block unwanted messages; most offer a quarantine option.



Monitoring — Does not intercept — it analyses stored messages for offensive words, attachment names and sizes, to detect abuse patterns and enforce policy.



Encryption — Sending unencrypted e-mail is like writing your message on the back of a postcard. Use zipped or encrypted files where the content is sensitive.

Judging an e-mail before you act on it

A bogus message may appear to come from someone you know or from a trusted source. Any message you were not expecting should be treated as suspicious.



RED FLAGS — STOP AND CHECK

- You were not expecting the message, or it arrives out of context
- It asks for date of birth, password, PIN, card or bank details
- It creates urgency: "your account will be closed today"
- The link text and the real destination address do not match
- The address contains extra spaces, underscores, hyphens or odd spelling
- Spelling and grammar are poor, or the logo is slightly wrong
- An attachment you did not request, especially an executable



WHAT YOU MUST DO

- Never reply to an e-mail requesting personal or financial data
- Never click a link to "verify" or "update" your account — type the address yourself
- Do not open attachments not addressed to you or unrelated to your work
- Delete chain letters, junk mail and unsolicited advertising without forwarding
- Verify by phone with the sender if there is any doubt at all
- Report the message to the IT Manager — do not just delete it quietly

Three file types to recognise

The first two categories carry "active" content — Windows will do whatever the file was programmed to do, good or bad. Malicious code has been moving out of attachments and into the message body: simply reading a message can launch an attack.



Executable files

Run code directly

Programs and scripts that execute when opened: .exe, .com, .bat, .cmd, .scr, .pif, .vbs, .js
. Never open one that arrives by e-mail unless you requested it and verified the sender.



Exploitable files

Contain macros or embedded code

Office documents, PDFs and HTML that may carry macros or embedded scripts. They look harmless. Disable macros by default and only enable them for documents from a verified source.



Inactive files

Data only

Plain text and simple image data with no active content. Still treat with care — the file name and icon can be disguised, and combined attacks rely on you lowering your guard.

Assuming an identity without permission

Variations include masking, mimicking, impersonating and masquerading — tricking users into revealing passwords and other information used to reach their private accounts and assets.



IP spoofing

Masking IP packets so traffic appears to originate inside the network. Most systems are configured to trust internal traffic, which is exactly what the attacker exploits.



Web spoofing

The browser is tricked into serving a different address than the one it appears to resolve — by attacking DNS, or by modifying the displayed URL so it looks legitimate.



E-mail spoofing

Forging the header so the message appears to come from a genuine source such as the network administrator. SMTP has no authentication, which makes this easy.



Why attackers spoof e-mail

To make you release sensitive information, make a damaging statement, or act against your own interest — and to make investigators' work far harder.



Social engineering

The hacker term for tricking users into revealing passwords or performing tasks outside their normal behaviour. Virus writers use it to get attachments opened.

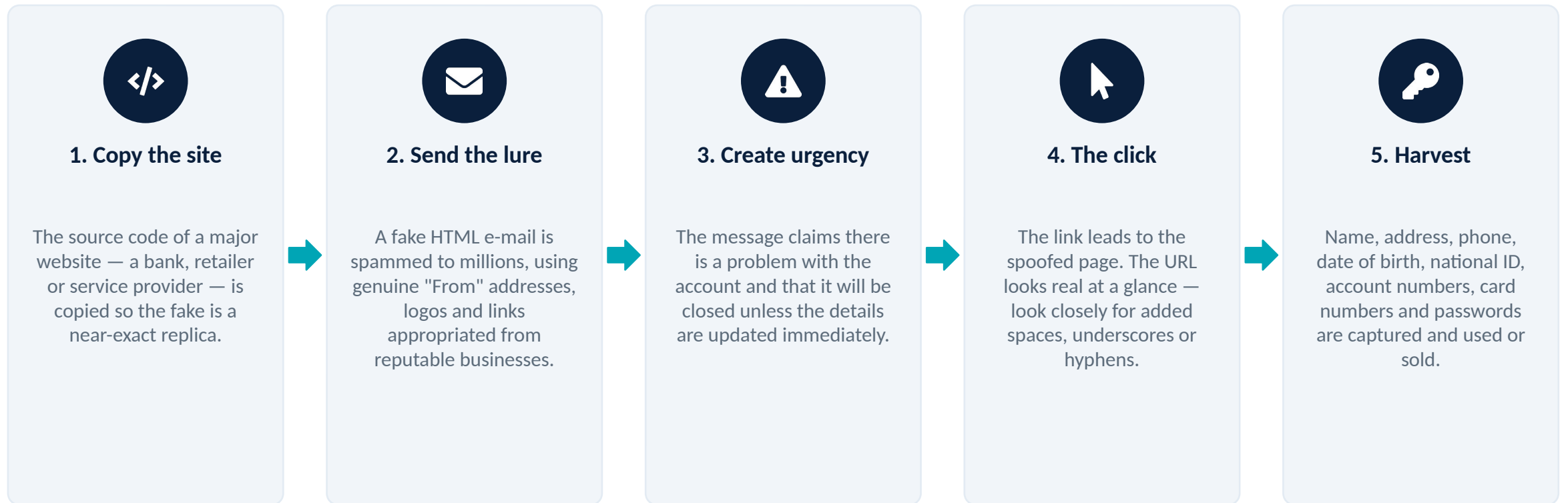


It is not only e-mail

The telephone works just as well: a confident caller claiming to be from the supplier, the office or the port authority can obtain more than any malware.

How the scam actually works

Phishing combines e-mail and the web into a single deceptive attack vector — the victim is "hooked" and led to a spoofed website.





SECTION 05

Malware

Any program introduced into a computer to cause damage, steal information, or act in an unexpected way — without the user's consent.

05

Most malware follows the four E's



Virus types you should recognise

A virus is a code fragment — not an independent program — that spreads by attaching itself to a host, then infects the applications transferred to other computers. Its two objectives are propagation and payload delivery.

Type	How it behaves
Boot sector	Replaces or implants itself in the DOS boot sector or the Master Boot Record. Hides in executable files attached to e-mail or shared documents.
File infector	Hides in program or application files (.exe, .dll, .pif, .com). Spread through USB sticks, CDs/DVDs, downloads or scripts sent as e-mail attachments.
Macro	Uses a macro language (e.g. Visual Basic) to modify common commands such as "Save" to trigger a payload. Activated by opening a shared document or spreadsheet — most often Word or Excel. About 75% of viruses in the wild.
Multipartite	Infects both files and the boot sector, so it can re-infect a system several times before it is finally eliminated.
Polymorphic	Has an encryption/decryption engine and an infector. Encrypts the infector with a different key each time, so no decryption key can be extracted from the engine.
Stealth	Hides its presence by making an infected file appear uninfected. Encrypted and armoured to make analysis and detection far harder.

Worms, Trojan horses and spyware



Worms

Self-contained and self-propagating

- Does not need a host program — it resides in active memory
- Uses OS facilities meant to be automatic and invisible to the user
- Often noticed only when replication consumes system resources
- Degrades service by generating enormous network traffic
- Sends junk e-mail, moves or deletes information, installs backdoors
- Needs a spread algorithm, one or more exploits, and a payload



Trojan horses

Appears useful, hides something else

- An independent program that conceals an unauthorised function
- Two parts: a server installed on the victim, a client kept by the attacker
- Most are used as a backdoor or trapdoor for later access
- Turns PCs into "zombies" recruited into botnets
- A logic bomb is a Trojan with a trigger — a date, or a condition being met
- Spread by worms, but also heavily by peer-to-peer file sharing



Spyware

Quietly reports on you

- Uses the internet connection in the background to send data elsewhere
- Commercial versions build user profiles for advertising
- Malicious versions scan for proprietary data and contact remote hosts
- Collects personal, financial and behavioural information
- Logs keystrokes, captures screens, records conversations
- Often bundled with "free" software downloads

Trojan vs. worm vs. virus

	Virus	Worm	Trojan horse
Independent?	No — a code fragment that needs a host program	Yes — self-contained	Yes — a stand-alone program
Self-replicating?	Yes, via the host it attaches to	Yes, actively across the network	No — it relies on the user to install and run it
Typical target	Specific applications such as Word or Excel	Any vulnerable host reachable on the network	The individual user who is persuaded to open it
Purpose	Disruption — it announces itself by the damage it does	Disruption and propagation	Concealment — it wants to stay hidden and give access

Trojans are not much different from the vectors that deliver viruses and worms; the key difference is purpose.



SECTION 06

Vulnerabilities & Risk Assessment

Find the weaknesses, judge the consequence and likelihood, then prioritise the fix.

06

Shipboard systems most exposed to attack

Stand-alone systems are less vulnerable than those attached to uncontrolled networks or directly to the internet. Understand how each critical system is actually connected.



Bridge systems

ECDIS, GNSS, AIS, radar/ARPA, VDR, LRIT, NavTex and integrated bridge systems.



Propulsion & machinery

Engine, steering and power control; increasingly connected for remote monitoring and maintenance.



Cargo management

Loading computers, ballast and stability software, shipment tracking, interfaces to shore systems.



Access control

Surveillance, electronic personnel-on-board systems, bridge and engine-room access control.



Administrative systems

PMS, requisitioning, crew management, certificates and electronic manuals.



Crew welfare

Crew internet, personal devices and social media — often the least controlled part of the ship.



Communications

Satellite terminals, VSAT, e-mail gateways and remote support links.



Supplier remote access

Maker and service-provider connections into navigation and other OT software.

Vulnerabilities frequently found on board

- Obsolete and unsupported operating systems that no longer receive security updates
- Outdated or missing antivirus software and malware protection
- Inadequate security configuration and best practice, including ineffective network management
- Shipboard computer networks that lack boundary protection and segmentation
- Safety-critical equipment always connected to the shore side
- Inadequate access controls for third parties, including contractors and service providers
- Missing or ineffective back-up and recovery arrangements
- Insecure design or configuration introduced by new technology



Makers and third parties

- Many suppliers lack their own cyber awareness training and governance
- Ask about internal governance for network security before awarding contracts
- Seek a cyber security assurance as part of the contract
- Service technicians must not use their own USB sticks on ship systems

Examples from actual vessel assessments

These are genuine observations recorded during cyber security assessments on board. Read them as a checklist of what not to repeat.



Technical findings

- Firewall mounted in the engine performance monitoring cabinet — but not connected
- No anti-virus on "island-mode" workstations; last scan in 2014, no scheduled scans
- Skype installed on the tank sounding computer
- Four base functions of the on-board firewall disabled, including event logging
- Broadcast storm protection disabled in switches; no network load monitoring
- Windows updated only during major upgrades — up to three years out of date
- Default credentials still in place on switches and routers
- Unencrypted e-mail communication; 15 anti-virus alarms in one week on a sample PC



Procedural and human findings

- No password change policy; passwords pre-set by shore IT and printed on the wall
- Weak passwords such as "123"; no automatic lock-out, users stay logged in
- Unnecessary administrator access on the engine performance monitoring PC
- Personal use of the company network — e-mail, browsing and social media on ship PCs
- ECDIS update USB stick not physically secured and never malware-scanned
- Single USB used for shore transfers; SD card shared between camera and workstations
- All backups stored in one cabinet on board and never transferred ashore
- No incident response policy defined; AIS left on in a piracy area against policy

The four phases of a cyber security assessment



The CIA model and impact levels

The confidentiality, integrity and availability model provides the framework for assessing both vulnerability and impact.



Confidentiality

Unauthorised access to, and disclosure of, information about the ship, crew, cargo and passengers.



Integrity

Loss of integrity — data or systems altered so that decisions are made on false information.



Availability

Loss of availability — the system or data cannot be reached or used when it is needed.



Three impact levels

- **LOW** — limited adverse effect: noticeably reduced function, minor damage or minor financial loss
- **MODERATE** — substantial effect: significantly reduced effectiveness, significant damage or non-severe injury
- **HIGH** — severe or catastrophic effect: one or more primary functions lost, major financial loss, severe or catastrophic injury

SCORING

Likelihood × consequence

High	Medium	High	High
Medium	Low	Medium	High
Low	Low	Low	Medium
	Low	Medium	High

LIKELIHOOD

CONSEQUENCE →



How we manage the result

- Use a consistent risk management framework for every cyber issue
- Do not pursue "perfect" security — seek sustainable, acceptable risk
- Link security controls to compliance reporting, so reporting shows real security and not just compliance
- Define risk in enough detail to procure cyber insurance intelligently
- Re-assess when normal controls are invalidated — dry-dock, take-over of a new or existing ship, major refit
- Combine technical and procedural defences: both are required



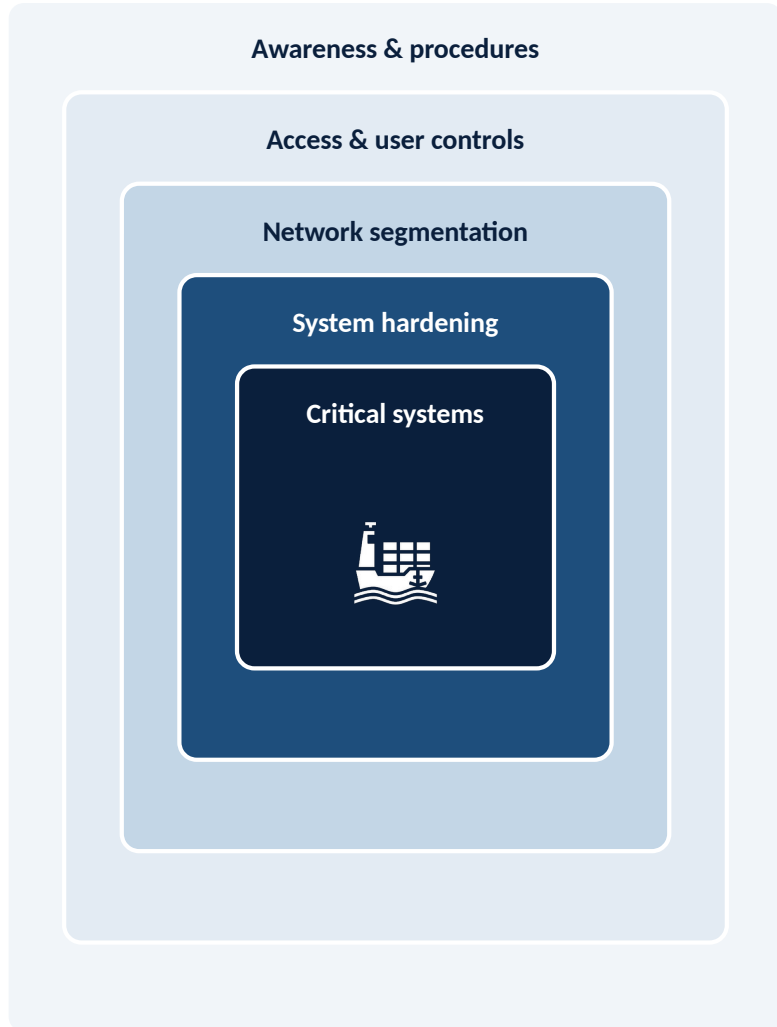
SECTION 07

Developing Protection Measures

Cyber security starts at senior management level — not with the SSO or the IT department alone.

07

Layers, not a single wall



Intrusion detection — monitors traffic and alerts on abnormal behaviour.



Software whitelisting — only approved applications are allowed to run.



Access and user controls — least privilege, individual accounts, no sharing.



Removable media rules — controlled, scanned and physically secured.



Password policy — strong, unique, changed on crew change and reassignment.



Awareness — personnel who recognise the risk and follow the procedure.

People, process and technology

With a large proportion of breaches caused by people and poor processes, technology alone will never be enough.



People

Cyber hygiene · Training and awareness · Professional skills and qualifications · Screening and background checks · Supervision of unscreened personnel in controlled spaces.



Process

Management systems · Policies and procedures · Handling of vendors and third parties · Drills and audit regimes · Monitoring and logging of all access to systems.



Technology

Antivirus · Firewalls · Intrusion detection · Software updates and patches · Functional testing, vulnerability scanning and penetration testing.

Protecting the boundary and the hardware



Screen before delivery

Communication paths and messaging — e-mail and social messaging — are screened before delivery to the recipient, to detect and remove hazardous files, attachments and links.



Protect the perimeter

Perimeter and protected internal boundaries are defended by firewalls, gateways, routers and switches with logging enabled.



Secure the equipment

All computational equipment controlling safety-related operations is physically secured, and interfaces to those systems are protected.



Fail safe, not shut

Login failures, lockouts, loss of power and reboot events must not impact safety-critical operations.



Dispose properly

Equipment leaving the ship or the office is wiped; no drive, card or device leaves with recoverable company data on it.

NON-NEGOTIABLE

Connecting a personal device to the ship network is prohibited

PCs, tablets, phones and USB sticks brought on board are for personal use only, on the crew internet connection. USB and RJ-45 ports on ship computers are locked or deactivated by the licensed antivirus software, and only the vessel's officers hold the passwords to enable them.

No personal PCs

No personal USB

No unapproved Wi-Fi

Segmentation, firewalls and links to shore



Controlled vs. uncontrolled networks

Decide which systems attach to which. Controlled networks prevent security risks from connected devices using firewalls, gateways, routers and switches. Networks critical to the operation of the ship must always be controlled.



Partition into safe zones

On-board networks are partitioned by firewalls to create zones. The fewer communication links and devices in a zone, the more secure it is. Confidential and safety-critical systems belong in the most protected zone.



Satellite and radio

Cyber security of the satellite and radio link is agreed with the service provider. The link specification must be considered when setting requirements for on-board network protection.



VPN and encryption

Where a VPN is used, traffic is encrypted to an acceptable international standard, with a firewall in front of the servers and computers connected on board and ashore.

Malware detection, configuration and change control



Malware detection

Scanning software that automatically detects and addresses malware is kept regularly updated. On-board computers are protected to the same level as office computers ashore.



Patch management

Critical safety and security updates are applied correctly and in a timely manner, so that flaws are closed before they can be exploited. Only signed updates obtained from the manufacturer are used.



Secure configuration

Only Senior Officers hold administrator profiles and control the set-up and disabling of user profiles. User profiles are restricted to the purpose the machine was provided for.



Change control

An authorisation process governs hardware, software, firmware, architecture and configuration upgrades. No unexpected, unattended or unauthorised change is permitted on critical systems.



The management cycle

Threat → vulnerability → configuration → patch → change → risk. Each new piece of software or configuration change is considered against the whole cycle.

Access management and authentication

- Personnel are screened for security issues before joining the vessel.
- Group logins and shared credentials are prohibited — every user has their own account.
- Two-factor authentication is required to reach sensitive resources and assets.
- Authorised third-party personnel must use two-factor authentication, or strong passwords that cannot be easily guessed.
- A third-party supplier programme defines supplier expectations and access conditions.
- Guest wireless access requires login credentials so usage can be tracked.
- Login failure time-out periods are implemented to defeat password guessing.
- Single sign-on boundaries are decided on the basis of data sensitivity and application criticality.
- Administrator privileges are given only to appropriately trained personnel who need them, and their use is limited to the task in hand.



Why suppliers are a special risk

Suppliers and contractors often combine intimate knowledge of the ship's operations with full access to its systems. Restrict their access, supervise it, log it, and withdraw it as soon as the work is complete.

Virus detection and prevention — the crew rules

✓ DO

- Back up important files regularly and store the copy away from your work files
- Verify that an anti-virus program has checked any file before you open it
- Send sensitive material as a zipped or encrypted file when necessary
- Use configured user accounts — avoid generic mailbox addresses
- Delete chain e-mails and junk mail without forwarding them to anyone
- Report anything suspicious to the IT department immediately

⊘ DON'T

- Do not open files attached to e-mails that are not addressed to you or your department
- Do not open attachments that are odd, suspicious or unexpected — even from a known sender
- Do not download files directly from the internet, or any file from a stranger
- Do not click hyperlinks in e-mail; type the address into the browser instead
- Do not use ship computers for personal browsing, social media or private e-mail
- Do not disable the anti-virus software or the port locks for convenience

Removable media, obsolete equipment and visitors



Removable media

A dedicated, physically secured and malware-scanned stick for each purpose — never a shared one. Never move a stick between a shore PC and a ship system without scanning it. Cameras, SD cards and phones count as removable media too.



Unsupported hardware & software

Equipment no longer supported by the producer receives no security updates. Its continued use must be carefully evaluated and compensating controls applied. Routers, switches, firewalls and OT devices run firmware that also needs regular updates.



Access for visitors

Authorities, technicians, agents, port officials and owner or manager representatives are restricted from computer access on board. Unauthorised access to sensitive OT network computers is prohibited through clear procedures and supervision.

Training and awareness

The internal cyber threat is considerable and should not be underestimated. Personnel protect IT and OT systems — but they can also be the cause of an incident.



Risks of own devices

Personal devices may be missing security patches and anti-virus, and transfer that risk to whatever they connect to.



Risks of installing software

Installing and maintaining software on company hardware without authorisation introduces unknown code onto the network.



Detecting suspicious activity

Strange connections that are not normally seen, or someone plugging an unknown device into the ship network — and how to report it.



Signs a computer is compromised

Unresponsive or slow system; unexpected password changes or lock-outs; unexpected errors; unusual network activity or disk usage.



Anti-malware is not enough

The presence of anti-malware software does not remove the requirement for robust procedures, especially control of removable media.



Who is trained

- On board: Master, Officers and crew
- Ashore: personnel supporting management and operation of the ship
- Third parties: contractors informed during familiarisation
- Delivered through seminars, drills and this awareness programme



SECTION 08

You Are the Front Line

Most attacks succeed because a person clicked, plugged in, or shared something. Most attacks fail for exactly the same reason.

08

Your workspace and your devices



Your workspace

- People you do not know may be in your physical space, in the office and at other work locations
- Do not allow unauthorised access to your work area
- Do not let anyone borrow your keys or your security badge
- Do not download or install your own software onto company equipment
- USB ports must be left locked or deactivated when the workplace is unattended
- Only vessel officers know the passwords that re-activate USB ports



Your devices

- Thieves look for easy ways to take PCs, phones and other devices
- Put away and lock your PC and other devices when you are not using them
- Ensure laptops and mobile devices are encrypted
- Take care with thumb drives — never plug an unknown one into any ship computer
- Report a lost or stolen device immediately; do not wait to see if it turns up
- Lock your session even during a short absence

Your password is the lock on the whole ship

The password is the most frequently used means of authenticating yourself on digital equipment. Its quality is essential to the protection of information and on-board equipment.



Make it strong

At least 8 characters, ideally 12, mixing uppercase, lowercase, numbers and special characters. Difficult to guess with specialised tools, but easy for you to remember.



Make it impersonal

Nothing related to you — no name, birth date, ship name or family details — and nothing that can be found in a dictionary.



Make it unique

Use different passwords for separate systems. Passwords protecting private accounts must never be reused in a professional context.



Change it when people change

Where an account is shared by multiple users, the password is renewed at every departure or reassignment. On board, passwords are changed monthly.



Never write it down

Do not store passwords in files or on paper. If you must save them, use a dedicated secure password solution. Change all default passwords as soon as possible.



The first-letter method

Take a sentence you will not forget and use the first letter of each word, adding numbers and symbols.

"My 2 sons were born in Istanbul on the 4th!"

becomes M2swbilot4!

Long, mixed, memorable — and not in any dictionary.

Inbox, browser, social media

The pattern is always the same: a threat arrives, you take an action, and there is a result. Break the chain at the action.



E-mail threats

Phishing, spoofs, hoaxes, malware, scams and spam. The threat: a message that looks legitimate, even from someone you know. The result: a harmful program launches, or you land on a harmful site and your details are compromised. Stop: do not click, and do not assume links in your e-mail are safe.



Internet threats

Browsing can be hazardous. The threat: malicious links. Most damage comes from clicking a link that launches a program or redirects you to a dangerous site. Remember that the information you leave on the internet stays there. Stop: verify the address before you click, and never install anything a website offers you.



Social media threats

The rapid growth of social networking has created new opportunities for hackers and thieves. The threat: links and messages that appear to come from friends. The result: malware, or a site that harvests your personal information. Stop: do not assume these sites are safe; use common sense and share nothing operational.

Mobile working, travel and online payment

✓ MOBILE & TRAVEL

- Use a VPN so that even a public access point gives you a secure connection
- Always encrypt mobile devices and keep the encryption enabled
- Install only necessary applications and check what data each one can access
- Back up your data before you travel, in case of loss or theft
- Keep devices and storage media with you — not in a hotel room or an office
- Disable Wi-Fi and Bluetooth when you are not using them
- Use a password, not only a PIN, and set the device to lock automatically

⊘ ONLINE PAYMENT & DATA

- Never transmit the four-digit PIN of your credit card — no one legitimate will ask
- Check for the padlock and that the address starts with https:// and is spelled correctly
- Fill in only strictly necessary information; untick boxes that let a site store your data
- Review your security and privacy settings regularly on every service you use
- Reduce professional information on social networks and be cautious in interactions
- Use dedicated e-mail addresses for different internet activities
- Never store passwords on your device, and never leave them in a file

THE BASIC CONCEPT

STOP. THINK. BEFORE YOU CLICK.

Most end-user threats are aimed specifically at getting you to click a harmful link, attachment, picture, video or icon — in an e-mail, on a web page, or in a social media application. You control what you choose to click.

Be aware

Be alert

Be diligent



SECTION 09

Contingency & Response

A cyber incident that takes out OT systems must be treated exactly like any other equipment failure — immediately and by the book.

09

Scenarios the plan must cover on board

The loss of OT systems may have a significant and immediate impact on the safe operation of the ship. This list is not exhaustive.

- Loss of availability of electronic navigational equipment, or loss of integrity of navigation-related data
- Loss of availability or integrity of external data sources, including GNSS
- Loss of essential connectivity with the shore, including the availability of communications
- Loss of availability of industrial control systems, including propulsion, auxiliary systems and other critical equipment
- Loss of integrity of cargo, ballast or stability data
- Event affecting the integrity of ship data — crew lists, cargo manifests, certificates, logs
- Loss of confidentiality of commercially sensitive data



Treat it like any other failure

When a cyber incident is discovered, every relevant person must know the exact procedure to follow — who to inform, what to isolate, what to record, and what not to switch off. That knowledge comes from drills, not from the manual on the shelf.

An effective response has four stages



The response plan and the IRP



Key decisions in the plan

- Which systems does this apply to?
- Should systems be shut down immediately, or kept running?
- Should certain ship communication links be shut down?
- Should pre-installed security measures be activated?
- Who is informed, in what order, and how quickly?
- What must be recorded before anything is changed?



The Incident Response Plan contains

- Lessons learned from previous incidents and events
- Notification lists for everyone who must understand or take part
- Communication arrangements, internal and external
- Roles, responsibilities and decision authority
- Evidence preservation and reporting requirements
- Recovery priorities and acceptance criteria



Preparation and drills

- Periodic cyber incident drills rehearsing recognition, control and recovery
- Incident preparation as a collective effort, ashore and afloat
- Table-top exercises to revisit disaster plans
- Initial training for new personnel, refresher training for the experienced
- Recovery plans accessible to Officers according to their responsibilities
- Confirmation that the security architecture still protects existing systems

Incident response flow

1

Identify the cyber attack or incident

Any crew member who notices unusual system behaviour reports it at once.

2

Inform the SSO and the Master

The Master informs the Head Office without delay — see the contact details at the end of this presentation.

3

Assess: can the system be rectified without shutting down?

If yes, rectify and verify. If no, determine whether a back-up system exists and whether the vessel is free of immediate danger.

4

Isolate or switch over

Use the back-up system where available. If the vessel is not free of danger, inform Head Office and all parties concerned and consider stopping the vessel.

5

Rectify, verify and return to service

Ask for external or manufacturer assistance where needed. Perform all relevant checks before putting the system back on line.

6

Inform crew and Head Office for rectification

Then proceed to full incident investigation under the company SMS.

Investigating a cyber incident

Follow company SMS procedures, M11 Main Manual. Investigation reveals how the vulnerability was exploited — information that improves our approach for every ship.



Initial investigation

The precise nature may be unknown at first. The approach may be internal, or external where specialist expertise is required.



Examine the evidence

Important alerts and suspicious events in logs and monitoring systems (IDS, IPS), correlated with network data including cloud providers, and compared against threat intelligence.



Record every trigger event

Date and time • IP address, internal or external • Port, source or destination • Domain and file (.exe, .dll) • System, hardware and software involved.



Report

The report covers who the Company reports to, what it must contain, its format and its objective — including a full description of the incident and its impact.

Follow-up that actually prevents recurrence

In practice these actions are often skipped through lack of resource or competing priorities. They are the part that stops the same incident happening twice.



Investigate more thoroughly

Problem cause analysis, root cause identification, and quantification of impact — financial, operational, reputational, management and compliance.



Post-incident review

How well did staff and management perform? Were documented procedures followed and were they adequate? What would we do differently next time? How could information sharing be improved?



Lessons learned

Document, communicate and build on what was learned — an ongoing process, not a single report. Update procedures, control measures and related documents.



Trend analysis

Analyse cyber incidents like any other incident, on board and ashore: evaluate patterns and trends, identify common factors, and target the measures that will have most effect.

If a vessel is involved in a cyber incident

The Master informs the Company immediately, using the details below. Company, DPA and CSO hard-copy contact information is also available on board — see M5 Forms, Check Lists & Posters, P-09 "DPA & CSO Emergency Contact".



Furkan NAIBOGLU

Designated Person Ashore (DPA)

Office +90 216 395 95 80

Mobile +90 542 826 32 96

E-mail mng@gloryship.com.tr



Kerem KARAARSLAN

Deputy DPA

Office +90 216 395 95 80

Mobile +90 541 320 92 03

E-mail mng@gloryship.com.tr



Investigators: Company incidents — IT Manager / Company Security Officer. Vessel incidents — initial: SSO; follow-up: IT Manager / Company Security Officer.



Cyber security is everyone's watch

Technology can only take us so far. The strongest control on this ship is a crew member who stops, thinks, and reports.



Stop and think before you click



No personal devices or unknown media



Strong, unique, protected passwords



Report anything unusual immediately